基于当前实现 · 待评审

学生学期综合素质评价系统
概要设计

V1.0（当前实现评审稿） | 2026-10-23

用途：现状核对 / 技术评审 / 整改确认

3 个账号角色 / 19 个非错误视图 / 35 条主 API 路由 / 17 张仓库表定义
正文仅描述已有代码；模拟、契约差异和未实现能力明确区分。

目录

一、系统定位

二、术语表

三、角色说明

四、总体结构与模块功能

五、模块怎么互动与关键处理流程

六、限制、风险与待确认事项

七、评审与审批确认

一、系统定位

1.1 文档目的与编写边界

本文件用于评审当前仓库代码已经编写的系统结构、页面入口、业务处理和数据组织，为功能核对、联调、部署检查与后续整改提供共同基线。依据用户最新要求，正文不以 plan、SPEC 或设计原型中的规划功能替代实际实现。

文档口径："已有"表示已发现对应源码或路由，不表示已经在真实数据库、生产环境或完整 UAT 中验证通过。当前运行数据库结构、实际部署规模和线上运行状态未在本次编写中核验。

依据	本版如何使用
当前源码及仓库 DDL	实现事实的主要依据：frontend/src、backend、sql/00_full_schema.sql；记录源码内容摘要，便于复核。
附件《学生学期评价系统·概要设计》v0.2	仅借鉴七章结构、术语表、模块表、蓝/绿/琥珀色提示、内嵌图及审批区；不继承其业务结论。
SPEC 正文 V2.1、实施计划、31 页原型与逻辑图	仅用于说明背景、约束与差距；不能证明对应功能已经落地。
本次证据范围	静态阅读和文档校验。未启动业务数据库，未运行会写入数据库的集成测试，未改动产品代码。

附件旧口径	当前实现的实际口径
钉钉登录、家校关系同步	当前为本地账号 + BCrypt + JWT；没有钉钉登录与名单同步适配器。
指定 / 不指定发卡、扫码直接到账	当前为教师归属的月度实体卡；学生申领先待审，教师通过后 +1；另有无卡直评入口。

附件旧口径	当前实现的实际口径
五方向积分、班级名次、家长入口	代码采用 D/Z/T/M/L/G 六维；未发现独立家长入口、名次计算及公开排行模块。
外部故事 60/40 合成、教师发布后家长确认	当前没有外部平台取分和 60/40 合成；报告由管理员接口直接生成发布，无家长确认流程。

1.2 项目目标与当前功能范围

服务谁 学生、教师、管理员三种本地账号角色。
记录什么 六育过程积分、荣誉材料、月度生活故事、学科与维度成绩。
怎样评价 实体卡审核入账与教师无卡直评；故事教师终审；评分引擎汇集 B/P/H。
怎样输出 个人账本、综合评价、管理员发布的报告快照，以及带水印的 HTML 打印视图。
当前边界 已有一组业务页面与控制器，部分链路仍存在字段、状态和安全校验差异，属于需要联调和整改的当前实现。

类别	当前实现覆盖	说明
评价采集	配额配置、批量制卡、令牌预览、申领、审核、批量直评、积分冲销	主要写操作具有部分事务及唯一约束控制，幂等与范围校验并未全面闭合。
材料与成绩	荣誉路径登记/补交/审核、故事草稿/提交/终审、JSON 成绩预览与提交	证书只登记文件路径；故事 AI 为本地模拟；导入不是现成的 Excel 文件上传服务。
汇总与报告	规则保存、综合得分查询、报告批量生成发布、本人报告查询、HTML 打印	有页面与接口，但前后端字段契约及发布前置条件仍需核对。
基础与运维	登录退出、学期保存、指标树查询、审计查询、健康检查、进程内定时器	没有完整账号管理、指标写管理、任务中心或真实消息投递闭环。

1.3 本版不计入当前能力的事项

- 31 页原型里尚未落入生产路由的个人自述编辑、独立消息中心、班级成长页、期末评语确认、账号管理、故事任务配置等。
- 独立家长账号、钉钉及外部小程序接口、外部故事加权合成、积分兑换、在线申诉、排名。
- 真实证书文件上传与对象存储、真实大模型调用、持久化任务队列、异步 PDF 文件生成和短期签名下载。
- 荣誉 REVOKED 撤销、报告发布后自动级联重算、归档后超管更正完整闭环、严格六项发布门禁。
- Redis / Spring Boot / MinIO / 独立 Worker 并非当前已集成技术；实施计划中的相关选型不作为本版现状。

1.4 当前学期业务主线



当前代码未提供独立的班主任报告确认环节，也未实现完整归档门禁。

图 1 当前代码中的学期业务主线（存在实现不完整项，不等同于已通过全流程验收）

二、术语表

2.1 业务与技术术语

术语	当前代码中的准确含义
六育	D 德育、Z 智育、T 体育、M 美育、L 劳育、G 故事；前后端个别样例出现 X，与 G 不一致，列入整改。
A 模式 / 无卡直评	教师（接口也允许 manager）选择学生及三级指标，控制器为每位学生新增 +1 积分流水。
B 模式 / 实体卡	管理员批量生成归属教师的卡片；学生用令牌预览、确认申领；审核通过才记 +1。
过程净积分	score_record 的 delta 求和。控制器写入 +1 或冲销 −1，不等于六育正式百分制成绩。
荣誉认定分	honor_record.honor_points 为 STORED 生成列；计算时只汇总 APPROVED 状态。
月度故事终审分	story_submission.teacher_score，教师提交后状态为 REVIEWED；当前评分引擎以最新一篇已评故事覆盖 G。
AI 建议	当前 mockEvaluateStory 根据文字长度生成模拟分数及评语，不是外部 LLM 推理结果。
成绩导入	后端接收 JSON items 数组进行差异比对和提交；当前前端传 records，尚未形成统一闭合契约。
综合分	B 六维均分、P 过程标准分、H 荣誉标准分的加权结果；缺维度时 comprehensiveScore 为 null。
规则版本	comprehensive_score_rule.rule_version；当前 DDL 使用 DRAFT/ACTIVE/SUPERSEDED，与 SPEC 的 DEPRECATED 不同。
报告快照	term_report.snapshot_json，存生成时的学生、评价、学科、荣誉等内容；发布接口直接生成 PUBLISHED。
PDF 导出	当前 URL 名为 export-pdf，但返回 text/html 打印视图；浏览器可自行打印，不是后端生成的 PDF 文件。
Outbox	notification_outbox 的消息记录与扫描代码；当前投递为模拟标记，且扫描字段与 DDL 不一致。
幂等 / 审计	通过请求键、唯一约束及 operation_audit 防重和追溯的设计基础；当前部分写接口未稳定复用请求键。

2.2 业务不变量与当前实现边界

规则	当前可见实现	不能据此推导的结论
直评/卡审核固定 +1	控制器插入 delta=1；冲销插入 delta=-1	不代表所有写接口已完整校验学期、权限和幂等。
一码不重复成功入账	卡申领使用行锁，DDL 有卡/申领关联唯一键	不代表超期卡、跨校令牌和重复请求已全部处理正确。
账本纠错追加流水	reverseScore 新增 original_id 关联的 -1，不更新原流水	当前未建立独立数据库防篡改策略与完整超管能力门禁。
材料与报告版本留痕	material_revision 版本号、term_report.version 已存在	当前部分导入使用 UPSERT，报告发布也未形成完整受控更正事务。

三、角色说明

3.1 学生（student）

通过本地账号登录，进入成长首页及六个专用业务页。个人数据接口在部分查询中以会话主体覆盖外部 studentId，前端展示不等于后端全部范围校验已完成。

操作	当前入口与处理
查看	成长首页、六维积分与流水、综合评价、已发布报告。
申领	输入评价卡令牌后查询预览，再提交待审申请；未发现浏览器摄像头扫描接入。
申报	填写荣誉名称、级别、等次、日期、证书访问路径；支持补交材料。
写作	故事正文保存为草稿或正式提交，查看教师终审结果。
打印	通过报告导出 URL 打开带水印的 HTML；当前无异步 PDF 任务。

3.2 教师（teacher）

操作	当前入口与处理
审核	专用页面：扫卡审核、荣誉审核、故事评阅。
评价	无卡直评页面批量勾选学生与三级指标；控制器固定 +1。
查阅与导入	教师菜单复用 /admin/cards 查看评价卡、/admin/import 进入学科成绩页面；查询与写权限由接口另行决定。
范围控制	无卡直评调用 assertStudentInScope；其他读取和审核并非都做了同等强度的实时班级校验。

当前没有独立的教师“期末评语编辑并确认报告”路由；不能把故事终审操作等同于班主任报告确认。

3.3 管理员（manager）

操作	当前入口与处理
基础配置	创建/修改学期、切换当前/活动标记；浏览六育指标树。指标树没有对应新增/编辑/停用接口。
卡片管理	配置教师配额、指定教师/月份/类目批量制卡、查看卡列表及新制卡令牌。未发现完整作废与印刷任务接口。
成绩与规则	JSON 导入预览/提交、保存综合评分规则；规则保存接口默认使用 ACTIVE。
报告与纠错	批量生成发布报告；查询审计记录；以原流水 ID 发起 -1 冲销。
后台辅助	手动触发过期扫描；接口允许管理员执行部分教师操作，但未实现完整授权代审和专用超管能力模型。

3.4 页面、菜单与权限矩阵

App.jsx 当前声明 22 个懒加载视图：登录与共用工作台 2 个，学生专用 6 个，教师专用 4 个，管理路径 7 个，错误页 3 个。教师复用两处管理路径，不额外计为新页面。

能力	学生菜单	教师菜单	管理员菜单	当前后端角色限制
卡片预览/申领	有	无	无	预览仅 requireAuth；申领 requireRole(student)。
扫卡审核 / 直评	无	有	无专用菜单	审核、直评均允许 teacher/manager。
荣誉/故事	本人提交	审核/评分	无独立材料管理页	提交 student；审核 teacher/manager。
学期 / 配额 / 规则 / 发布	无	部分复用卡页面	有	写接口通常 requireRole(manager)。
成绩导入	无	复用导入页面	有	teacher/manager 共用同一组导入接口。
积分 / 综合分 / 报告	本人入口	部分功能无专页	有部分管理入口	多处查询仅 requireAuth；导出路由甚至未挂 requireAuth。
审计与冲销	无	无	有	路由要求 manager。

权限评审重点：前端 RequireAuth 只判断是否登录，没有统一按 userRole 拦截业务路由。菜单隐藏不能替代服务端对象归属、学校与任教范围校验。

四、总体结构与模块功能

4.1 技术架构与选择依据

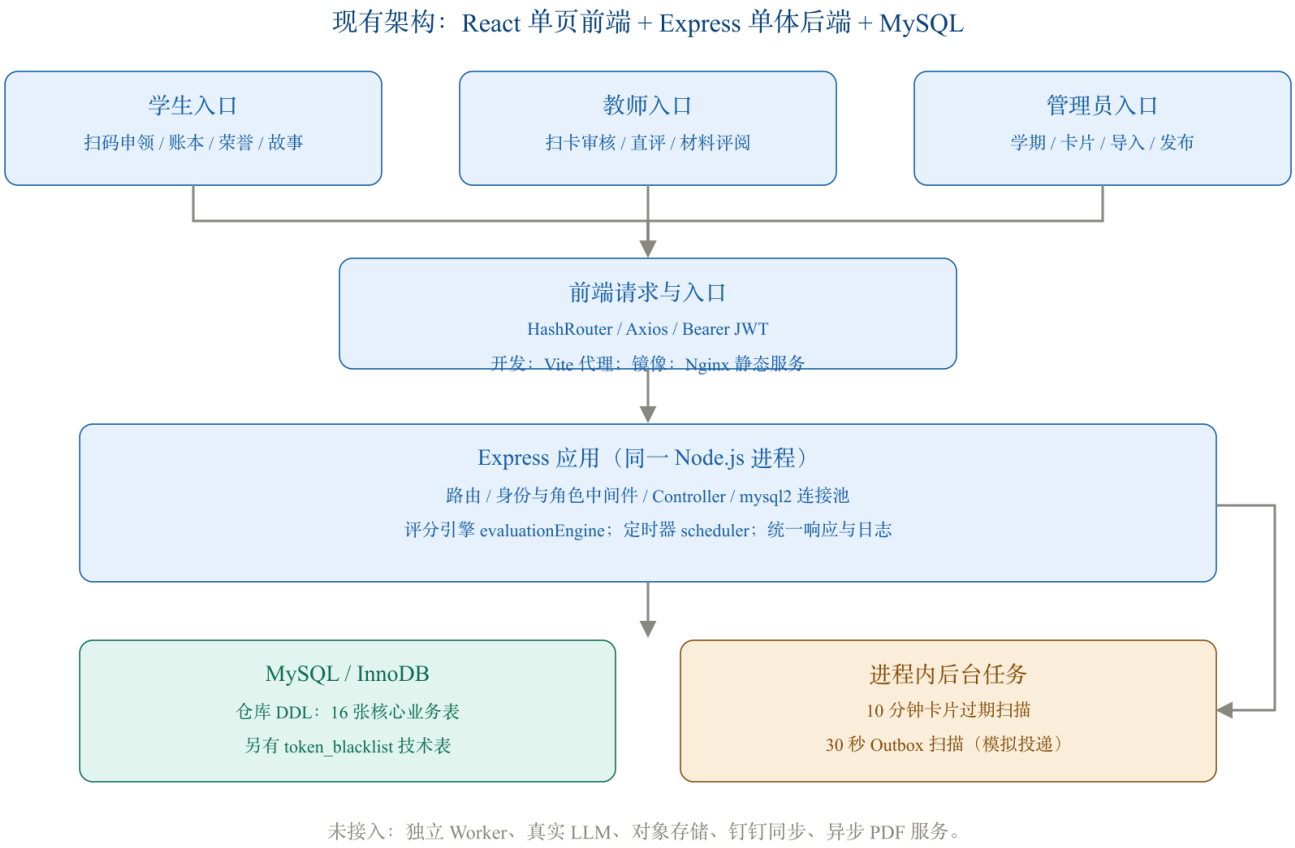


图 2 当前代码与 Dockerfile 定义的结构；不把尚未接入的服务画成现有组件

层次	当前实现	职责
前端	React 18、Vite 5、Ant Design 5、React Router、Jotai、Axios、Less	HashRouter 路由、角色菜单、表格/表单、请求封装、登录本地状态。
服务端	Express 5、Node.js、mysql2/promise、JWT、BCrypt	HTTP API、身份及角色中间件、Controller 中直接 SQL、评分服务与进程内调度。
数据	MySQL 8.0.16+ 兼容 DDL、InnoDB、utf8mb4	外键、CHECK、唯一索引、JSON 快照、生成列、显式事务及行锁。
部署定义	前端 node:20-alpine 构建 + nginx:1.25-alpine；后端 node:20-alpine	两个 Dockerfile 已存在；没有发现 Compose 编排文件、实际集群配置及 CI 工作流。

当前是一个前端 SPA 配一个 Express 单体服务，业务分目录组织，而非微服务。实施计划中 Spring Boot、MyBatis、Redis、iText 等选型未出现在现有服务依赖中，本版不将其写为现状。

4.2 模块输入输出与职责划分

编号	模块	已有处理 / 输出	主要源码	实现边界
MOD01	账号、身份与会话	三角色登录/退出、me、开发环境建测试账号	authController、routes/auth、middleware/auth	BCrypt；JWT 负载含班级快照；黑名单查询失败时允许认证通过。
MOD02	学期与六育字典	查当前学期、列表、保存学期；读三级指标树	termController、categoryController	时区响应写为 Asia/Shanghai；没有完整校历/时间窗配置与指标写管理。
MOD03	评价卡与扫码审核	配额、按教师制卡、卡列表、预览、待审、通过/驳回	cardController	制卡数量未与配额形成闭合约束；重复执行会继续编号生成新卡；审核范围与日期校验不全。
MOD04	过程积分与冲销	批量 +1、-1 冲销、六维净分及流水	scoreController	直评随机拼接请求键；查询未按 termId 过滤；部分审计 INSERT 字段与 DDL 不同。
MOD05	荣誉与材料版本	PENDING 申报、版本补交、APPROVED/REJECTED 审核	honorController	证书为路径引用；事件键带时间尾缀，不能据此保证同赛事稳定去重；无 REVOKED。
MOD06	故事草稿与终审	DRAFT/SUBMITTED、版本正文、模拟建议、REVIEWED 分数	storyController	AI 按文稿长度模拟；终审接口没有完整班级/归档门禁；不等于真实 AI 能力。
MOD07	成绩差异与写入	JSON items 预览和事务提交，返回批次号	importController	UI records 与 API items 不一致；提交可跳过无效行，UPSERT 覆盖现有版本。
MOD08	规则与评分引擎	读/写权重规则、按学生即时计算综合分	evaluationController、evaluationEngine	无 ACTIVE 时使用默认规则；G 覆盖与确认态/版本选择需评审。
MOD09	报告生成、发布与打印	批量组装快照、版本递增、已发布查询、HTML 导出	reportController	没有独立确认流程；发布并非完整事务；默认评语/自述/家长寄语为代码模板。
MOD10	审计、日志和定时器	审计列表、请求日志、卡过期扫描、模拟 Outbox 投递	routes/api、utils/logger、services/scheduler	定时器与业务同进程；过期/消息字段存在 DDL 不一致；未接外部通知渠道。

4.3 前端页面组织与展示规范

分组	已声明的页面入口
共用	/login；/dashboard（按当前用户角色渲染成长首页、教师工作台或管理概览）。
学生	/student/claim、/student/ledger、/student/honors、/student/stories、/student/evaluation、/student/report。
教师	/teacher/claims、/teacher/direct-score、/teacher/honors、/teacher/stories。
管理 / 复用路径	/admin/terms、/admin/cards、/admin/categories、/admin/import、/admin/rules、/admin/reports、/admin/audits。
异常与重定向	/403、/500、未匹配 404；/ 重定向至 /dashboard。

当前 ConfigProvider 使用主色 #277460、正文 #25332d、边框 #e6ebe7、圆角 8px；白色工作区、浅灰绿底、侧栏分组菜单延续既有清爽风格。视图采用懒加载和全局 ErrorBoundary。独立 HTML 原型含 31 个视图，但不计为本段生产路由数量。

> 当前部分页面读取 snake_case、summary、calculation 等字段，而控制器返回 camelCase、dimensions、comprehensiveScore 等另一结构。页面存在不代表内容已经正确绑定，见 6.1。

4.4 数据分域与核心实体

仓库 sql/00_full_schema.sql 共定义 17 张表，即 16 张核心业务表与 token_blacklist 技术表。以下描述仓库结构，不替代运行数据库的 SHOW CREATE TABLE 核验。

数据域	表	核心内容与关联
基础	academic_year	学校、学年学期、起止日期、当前/活动标记；业务表通过 term_id 关联。
基础	users	账号、密码散列、student/teacher/manager、school_id、学生班级、教师 classes JSON。
基础	edu_evaluation_category	parent_id 三级树、代码、名称、score、status、version；业务记录引用 category_id。
卡片	card_quota_rule	学校/学期/月/教师唯一；quota_n 与 allocation_json。
卡片	reward_card	归属教师、月份、serial_no、token_hash、有效期和状态；used_student_id 在审核后填入。
卡片	card_claim	card_id、student_id、请求键、审核人、审核时间与原因；一张卡仅一条申领关联。
账本	score_record	学校/学生/学期/维度、来源、delta、card_claim_id、original_id、操作人、请求键与备注。
材料	honor_record	活动 title、event_key、级别/等次、honor_points 生成列、PENDING/APPROVED/REJECTED、当前材料版本。
材料	story_submission	学生/学期/月唯一，草稿/提交/已评状态、终审分、评语、当前材料版本。
材料	material_revision	owner_type + owner_id + version_no 唯一；文稿、file_ref、content_hash、LLM 建议。
正式成绩	student_dimension_score	D/Z/T/M/L/G 百分制、确认状态、版本、批次、确认人；与过程流水分表。
学科	subject_score	subject_code/name、raw_score、full_score、等级、缺考/免考、批次和版本。
核算	comprehensive_score_rule	school_id/term_id/rule_version 唯一；三项权重、P/H 阈值、规则状态。
报告	term_report	学生/学期/version 唯一；snapshot_json、规则版本、综合分、模板评语、自述/寄语、发布和阅读时间。
治理	operation_audit	actor_user_id/role、target、action、old_summary/new_summary、request_id、时间。
消息	notification_outbox	recipient_id/message_type/business_key 唯一；payload_json、state、attempts、scheduled_at、错误与发送时间。
技术	token_blacklist	token_hash、expires_at；用于退出登录后的 Token 失效查询。

4.5 索引、状态与数据一致性

实体	仓库状态 / 唯一键	当前代码注意点
实体卡	UNUSED → PENDING → USED / VOID；另有 EXPIRED	申领/审核按这些状态写入；定时扫描却使用 ACTIVE，不能认为过期闭环有效。
申领	PENDING / APPROVED / REJECTED / EXPIRED；card_id、request_key 唯一	行锁配合唯一约束限制重复申领；尚未形成同请求稳定返回原结果的完整协议。
积分	request_key、card_claim_id、original_id 唯一；delta CHECK 为 ±1	负向记录引用原 +1；不是数据库级绝对不可篡改，仍需权限与审计控制。
荣誉	PENDING / APPROVED / REJECTED；学生/学期/event_key 唯一	没有 SPEC 的 DRAFT/SUBMITTED/RETURNED/REVOKED；当前 REJECTED 同时承担退回文案。
故事	DRAFT / SUBMITTED / REVIEWED；学生/学期/月唯一	主表当前版本递增，material_revision 留历史；没有 ai_status 列。
规则	DRAFT / ACTIVE / SUPERSEDED；学校/学期/版本唯一	与报告共用 SUPERSEDED 字面值，但语义不同；不应误写成当前 DDL 已有 DEPRECATED。
报告	DRAFT / CONFIRMED / PUBLISHED / SUPERSEDED；学生/学期/版本唯一	DDL 提供四态，但当前发布代码直接插入 PUBLISHED，没有独立 CONFIRMED 接口。
学期	DDL 唯一键为 academic_year + semester	虽然索引名含 school，实际列未包含 school_id；无 timezone 和完整截止字段。

材料内容摘要当前有的按正文计算，有的按文件路径与说明计算；它不是对证书原始文件字节的完整性证明。逻辑图、SPEC 与 DDL 使用不同状态命名时，正文以当前代码/DDL 为现状，差异保留待核对。

4.6 内部调用与事务边界

处理	代码中的事务 / 锁	实际边界
申领 / 审核	beginTransaction，SELECT … FOR UPDATE，状态变更和积分/审计在事务内	尚缺全面对象范围、日期与 Outbox 写入闭环。
批量直评	整个循环置于同一事务，逐生做部分班级检查	不是逐生独立事务；任一 SQL 报错会整批回滚。请求键有随机尾缀。
冲销	锁原流水、检查既有冲销、追加 -1 与审计后提交	没有完整 school/归档/超管门禁；reason 在后端并未强制非空。
荣誉补交/审核	补交与审核各有事务；初次申报主记录与材料写入没有同一显式事务	初次申报存在部分成功的可能，重交不严查前序状态。
故事提交 / 评分	提交版本在事务内；评分直接 UPDATE	评分修改的审计、权限与归档保护没有完整实现。
导入提交	使用事务循环 INSERT … ON DUPLICATE KEY UPDATE	显式 invalid 行会跳过，并非“任何异常一律拒绝整批”；原版本可能被覆盖。
规则保存	事务内将旧规则置 SUPERSEDED 后插入新规则	未见自动全校重算任务，状态更新范围和版本策略需核对。
报告发布	代码逐生查询、更新旧版和插入新版	未包裹显式事务，不能宣称已具备发布原子性；快照查询字段还需与 DDL 对齐。

4.7 关键接口与当前调用契约

backend/routes/api.js 声明 35 条主路由，统一挂在 /api/v1，同时另挂 /api 兼容前缀。下表路径省略 /api/v1；权限列描述当前路由中间件，不代表所有对象归属已校验。

方法与路径	当前路由限制	用途与主要参数
POST /auth/login	当前未挂鉴权	校内账号登录 username、password；返回 token 与 user
GET /me	已登录	当前会话用户 返回学校、角色、班级等用户信息
GET /terms/current	当前未挂鉴权	当前活动学期 公开路由，未登录时按默认学校处理
GET /terms	已登录	学期列表 含本校及全局基线学期
POST /admin/terms	manager	创建 / 修改学期 id、academicYear、semester、startDate、endDate、isCurrent、active
GET /evaluation-categories	当前未挂鉴权	有效三级指标树 公开路由；读取 status=1

方法与路径	当前路由限制	用途与主要参数
GET /student/cards/preview	已登录	卡片只读预览 query.token；当前返回 cardId、教师名等
POST /student/card-claims	student	确认申领 token、requestKey；返回 PENDING，pointsCredited=0
GET /teacher/card-claims	teacher, manager	查询待审核申领 query.status，默认 PENDING
POST /teacher/card-claims/:id/decision	teacher, manager	扫码审核 decision=APPROVE/REJECT、rejectReason、requestKey
POST /admin/card-quotas	manager	保存教师配额 termId、teacherId、monthKey、quotaN、allocationJson
POST /admin/cards/generate-month	manager	批量制卡 termId、monthKey、teacherId、count、categoryId；返回新卡令牌
GET /cards	已登录	卡片列表 monthKey、status、teacherId；最近100条
POST /teacher/scores/direct-batch	teacher, manager	批量无卡直评 studentIds、categoryId/categoryCode、remark、requestKey
POST /admin/scores/reversal	manager	积分冲销 originalScoreId、reason、requestKey
GET /student/scores	已登录	净积分与流水 可有 studentId；学生以会话本人为准；当前不按学期过滤
POST /student/honors	student	荣誉申报 title/awardName、awardLevel、prizeLevel、awardDate、certificateUrl、description
POST /student/honors/:id/resubmit	student	材料补交 certificateUrl、description/reason；追加材料版本
POST /teacher/honors/:id/review	teacher, manager	荣誉审核 decision=APPROVED/REJECTED、rejectReason/comment
GET /honors	已登录	荣誉列表 status、studentId；学生限本人，最多100条
POST /student/stories	student	故事草稿 / 提交 title、content、monthKey、isDraft（兼容部分下划线参数）
POST /teacher/stories/:id/review	teacher, manager	故事终审 teacherScore、teacherComment；另兼容部分别名
GET /stories	已登录	故事列表与材料建议 按当前角色构造查询，返回材料版本与模拟建议
POST /import/preview	teacher, manager	JSON 导入差异预览 type=SUBJECT 或其他分支、items 数组
POST /import/commit	teacher, manager	JSON 导入确认 type、items、termId；返回 batchNo、committedCount
GET /student/comprehensive-score	已登录	即时综合核算查询 studentId、termId；返回 isComplete、missingDimensions 等

方法与路径	当前路由限制	用途与主要参数
GET /admin/evaluation-rules	manager	读取 / 保存评分规则 GET 列表；POST 权重、阈值、ruleVersion、ruleStatus
POST /admin/evaluation-rules	manager	读取 / 保存评分规则 GET 列表；POST 权重、阈值、ruleVersion、ruleStatus
POST /admin/reports/publish-batch	manager	生成并批量发布报告 studentIds、termId；返回 published、blocked
GET /student/reports/current	已登录	查询已发布报告 studentId、termId；学生读本人，首次阅读会写 read_at
GET /student/reports/:id/export-pdf	当前未挂鉴权	HTML 打印视图 当前未挂鉴权，按报告 ID 查询并返回 text/html
POST /admin/tasks/trigger-card-expiration	manager	手动执行过期扫描 返回 expiredCount；当前扫描语句与 DDL 状态不一致
GET /users/students	已登录	本校学生列表 仅 requireAuth，未限制为教师或管理员
GET /users/teachers	已登录	本校教师列表 仅 requireAuth
GET /admin/audits	manager	审计记录 管理员查询本校最近100条审计

另有 /api/auth/login、/api/auth/me、/api/auth/logout；开发环境 /api/auth/dev-create-user 创建测试账号，非 development 时拒绝；/api/health 只返回进程状态与时间，不检查数据库就绪。前端登录仍调用 /api/auth/login，业务请求通常调用 /api/v1。

成功与业务冲突报文（当前格式示例）

```
POST /api/v1/student/card-claims
Authorization: Bearer <token>
Content-Type: application/json

{"token":"<card-raw-token>","requestKey":"CLAIM_EXAMPLE_01"}

// 成功响应：未提前加分
{"code":200,"message":"申领已提交，等待教师审核","data":{
 "claimId":501,"cardId":801,"status":"PENDING","cardStatus":"PENDING",
 "category":"主动帮助同学","pointsPending":1,"pointsCredited":0
}}

// 示例冲突：HTTP 409
{"code":4091,"message":"该实体卡已被扫码申领，正在教师审核中","data":null}
```

success/fail 通常返回 code、message、data；统一异常中间件的部分分支只有 code、message。业务错误码为数值（例如 CARD_PENDING=4091），不能把常量名称误当成现有字符串响应字段。分页大多为固定 LIMIT，不是完整 page/pageSize 协议。

接口对齐重点：导入前端传 records/subject/dimension，后端接 items/SUBJECT；综合评价前端期望 status/calculation 等结构，后端主要返回 isComplete/comprehensiveScore；这些是当前集成问题，不在本文件中虚构已兼容。

4.8 部署定义与运行环境

项目	仓库当前定义	评审注意点
前端开发	Vite 开发服务通常为 5173，/api 代理至 localhost:3000	实际端口以启动输出和环境配置为准。
后端开发	node app.js / nodemon app.js；PORT 默认 3000	非 test 模式启动进程内定时器；不能无数据库就认定业务已就绪。
数据库	mysql2/promise；主机/端口/库名由 DB_* 指定；连接数默认10	示例库名 template_db 不是固定业务约束；真实数据库版本与结构未实测。
前端容器	Node 20 构建 dist，Nginx 1.25 监听80并将 /api/ 代理到 backend:3000	需要名为 backend 的服务网络；仓库未提供完整 Compose 编排。
后端容器	Node 20，生产依赖安装，监听3000	默认不会把 frontend/dist 自动复制到 backend/dist；独立 Nginx 与后端静态托管是两种路径。
静态托管	backend/app.js 仅在 backend/dist 存在时托管该目录	不能根据 README 认为前端构建产物已自动进入后端镜像。
HTTPS 与持久化	Dockerfile 未配置 TLS 终止、证书、数据库持久卷及对象存储	部署方案需补充；不写成当前已启用能力。
调度与扩容	setInterval 与 Express 在同进程；没有独立任务进程和分布式任务锁	进程重启会重置定时器；多实例会重复启动扫描。

配置项	当前含义 / 默认差异
DB_HOST / DB_PORT / DB_NAME / DB_USER / DB_PASSWORD	由环境提供数据库连接；本文件不写入任何实际凭据。运行账号默认回退 root 的做法须在部署前处理。
DB_CONNECTION_LIMIT	默认10；未给出经过压测确认的容量值。
JWT_SECRET / JWT_EXPIRES_IN	存在开发默认密钥；代码有效期回退8h，.env.example 为7d，最终由真实环境覆盖。
PORT / CORS_ORIGIN	默认3000 / http://localhost:5173；生产来源白名单需按环境配置。
NODE_ENV	development 允许开发建用户；test 不启动监听和调度。
VITE_API_SERVER	前端 API 地址前缀，开发可留空走 Vite 代理。

版本维护风险：现有 Dockerfile 固定 Node 20；编写时官方发布页已将其列为 EOL。它是现状，不是本版对生产环境的推荐。升级至仍受支持的 LTS 并验证原生依赖应列为部署前整改。来源：Node.js 官方发布状态（2026-10-23 查阅）。

仓库存在旧模板 seed.js（admin/user 角色与简化 users 表）和业务 init_db_data.js（student/teacher/manager）。两者不能当作等价初始化方案；后者也会更新测试用户密码和班级。需先核对目标库、备份及 DDL，再在隔离环境执行，本文不执行初始化或给出“一键生产部署已可用”的结论。

五、模块怎么互动与关键处理流程

5.1 跨模块输入输出

触发者与操作	经过模块	当前主要读写与结果
用户登录	MOD01 → 前端会话	按 username 查用户并校验 BCrypt，返回 JWT 与用户；Axios 后续带 Bearer。
管理制卡 / 学生申领 / 教师审核	MOD02 → MOD03 → MOD04	读取学期、三级指标和卡；待审后通过，写入卡状态与 +1 流水。
教师无卡直评	MOD02 → MOD04	校验部分班级范围和指标，批量 +1，写审计。
学生荣誉申报及教师审核	MOD05 → MOD08	保留主记录/材料版本，已通过生成列分值在计算时汇总。
学生故事提交及教师终审	MOD06 → MOD08	正文保存多版本和模拟建议；最新已评终审分在当前引擎中覆盖 G。
成绩预览并确认	MOD07 → 维度表 / 学科表	JSON 比对旧新值，提交时事务写入并产生 batchNo。
综合查询与报告发布	MOD08 → MOD09	计算 B/P/H；发布端重新取分、学科和荣誉，组装 snapshot_json。
过程纠错 / 查询审计	MOD04 → MOD10	新增 -1，查询审计；当前不自动串起报告新版本的完整更正流程。

5.2 登录、退出与范围判断

- 登录参数为 username/password，当前按 username 查第一条用户，没有 schoolId 登录选择；同名跨校账号的确定性需核对。
- 验证账户状态、BCrypt 密码后签发 JWT，携带 userId、schoolId、role、grade、class_no、classes；当前 classes 是签发时快照。
- requireAuth 校验签名与注销黑名单；黑名单查询异常时当前会降级放行，不能声称撤销会话在故障下仍严格生效。
- 退出将 Token 的 SHA-256 与过期时间写入 token_blacklist；前端清理本地登录态。
- 菜单按角色组织，前端路由仅要求登录；服务端 requireRole 与局部 assertStudentInScope 共同构成当前权限基础，尚未成为全入口统一范围守卫。

5.3 配额、制卡、扫码申领与审核

1. 管理员设置 quotaN 与 allocationJson，控制器校验各分配值合计等于总额并保存。
2. 批量制卡接口另接 count、teacherId、categoryId；查询当前最大 serial_no 后继续增加序号，生成 32 字节随机令牌，存 SHA-256，返回原始令牌用于当前页面展示。
3. 学生输入 token 后 GET 预览；该接口只查询，并按 USED/PENDING/EXPIRED/VOID 返回不可用提示。
4. 确认申领事务锁定卡片，要求当前状态 UNUSED，插入 PENDING 申领并将卡置 PENDING；响应明确 pointsCredited=0。
5. 教师/管理员审批事务锁定申领关联查询；通过更新 APPROVED 和 USED，写 B_CARD +1 与审计；驳回更新 REJECTED、VOID 并写审计。

这是当前状态流转逻辑，不表示完整时效与授权保证。预览/申领未完整核对 school、valid_until 和学期时间窗；审核未完整校验原卡教师、授权代审条件，驳回理由也未强制。过期任务存在状态名不一致，见 5.10、6.1。

5.4 批量直评、账本与冲销

直评接收 studentIds 与三级类目；teacher 调用 assertStudentInScope，manager 分支直接查询学生。事务中每位学生新增一条 A_DIRECT/+1，随后写审计。当前请求键附加时间和随机值，同一请求重试不能据此保证仍命中原记录。

积分查询按学生和学校汇总 delta，并倒序返回最近200条流水；当前 SQL 未使用 termId，因此该接口展示口径是查询到的全部学期累计，不能写成严格“当前学期积分”。评分引擎另按 termId 聚合。

冲销由 manager 路由发起，锁定原记录，要求 delta 为正、尚无 original_id 关联冲销，再新增 REVERSAL/−1 与审计。原 +1 保留，唯一键防同一原记录第二次冲销。当前没有完整的强制理由、归档边界和超管能力检查。

5.5 荣誉申报、材料补交与认定

学生填报 title/awardName、级别/等次、日期、certificateUrl 与说明。控制器写 PENDING 主记录及第一版 material_revision；未提供文件二进制上传服务，缺路径时会使用模拟文件路径。event_key 由标题摘要与时间尾缀组成，不是稳定赛事届次键。

当前教师审核 decision 使用 APPROVED / REJECTED；不等同于扫卡接口的 APPROVE / REJECT。审核通过后，评分引擎汇总 honor_points；REJECTED 不参与求和。补交按原主记录追加 material_version，再回 PENDING；当前重交接口没有严格限定只可从退回态进入。

级别	一等奖 FIRST	二等奖 SECOND	三等奖 THIRD
省 PROVINCE	9	8	7
市 CITY	6	5	4
区 DISTRICT	3	2	1

当前没有独立 RETURNED 与 REVOKED 状态、荣誉撤销接口及其自动重算/新版报告闭环。不能把 SPEC 中的完整状态机描述为当前功能。

5.6 月度故事与模拟 AI 预评

提交以学生/学期/monthKey 查找主记录；正文修改增加 current_version 并保存 material_revision。isDraft 为真写 DRAFT，否则 SUBMITTED。mockEvaluateStory 依据文字长度返回建议分和固定文案，结果存为材料建议，不调用任何外部模型。

教师终审接 teacherScore 及评语，更新为 REVIEWED。评分引擎查询当前学期按 id 倒序第一条 REVIEWED 故事的 teacher_score 作为 G；这不是“所有月份平均”，也不是已批准的校内/外部故事合成规则。

当前没有完整的 AI PROCESSING/FAILED/SKIPPED 异步状态、月度任务配置、归档只读保护与终审修改审计。教师确认月度故事与班主任确认期末报告是两件事。

5.7 JSON 成绩差异预览与提交

1. 后端 previewImport 接 type（默认 SUBJECT）和 items 数组；预览阶段限制最多1000行。
2. 按 username 或 studentId 匹配本校学生，校验分数0—100，并查询旧值，返回 NEW/SAME/UPDATE 与 valid/error。

3. commitImport 再接 type、items、termId，在事务中写 subject_score 或 student_dimension_score；返回生成的 batchNo。
4. 显式 valid=false 的行会被跳过，其余行执行 UPSERT；当前不是“存在异常则禁止整批提交”的强约束。

当前前端页面为 JSON 文本框，传 type=subject/dimension 与 records，并读取 diff_items；后端接 SUBJECT/items 并返回 diffs。数据名称和结构均需对齐；不能描述为已具备统一的模板文件导入、2MB 文件解析、服务端预览凭证或正式版本追加能力。

5.8 当前综合得分计算

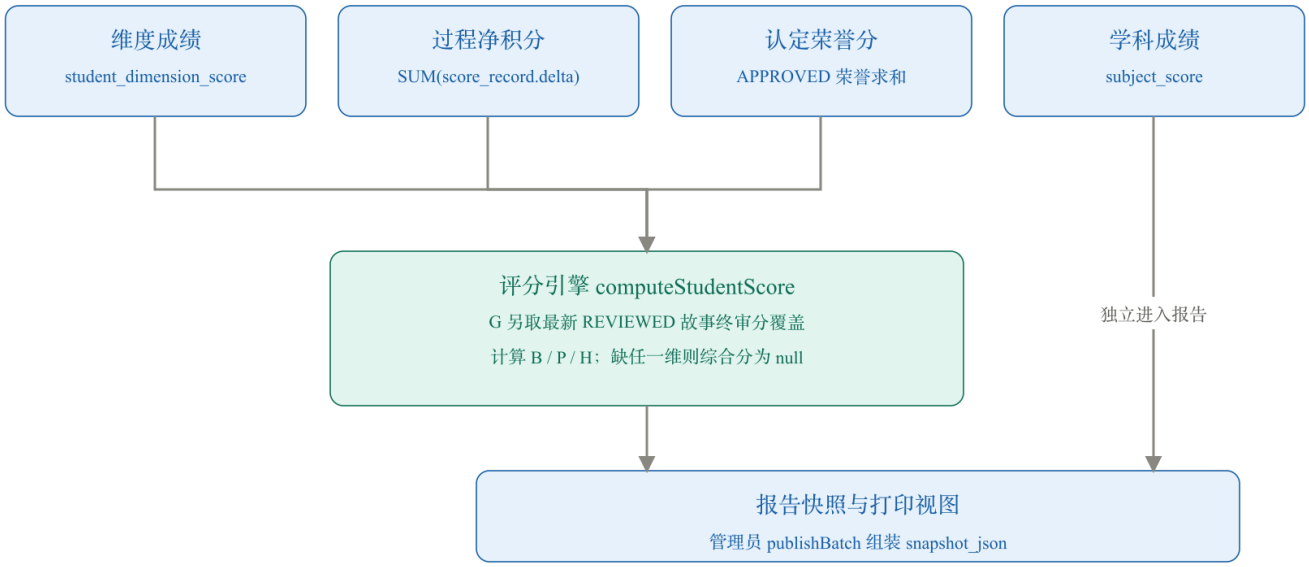


图 3 当前代码的数据汇集方式；最新故事覆盖 G、缺少确认态和版本筛选属于现行口径及风险，不代表最终校规

```
B = (D + Z + T + M + L + G) / 6
P = min(100, max(0, 净过程积分 / process_target × 100))
H = min(100, max(0, 已通过荣誉分 / honor_target × 100))
S = round(six_weight × B + process_weight × P + honor_weight × H, 2)
```

引擎读取 ACTIVE 规则；没有规则时当前回退80%/15%/5%、20次、12分。六维存在性检查通过才计算 S，否则返回 isComplete=false、缺失维度列表和 null 综合分。当前查询未严格限定 CONFIRMED 或明确最新版本，也会用最新已评故事覆盖 G，故完整性含义仅是“当前 Map 中有六个值”。

示例仅说明现有公式：六维92、88、90、86、94、89，B≈89.8333；过程33次→P=100；荣誉8分→H≈66.6667；按回退权重得到 S=90.20。实际评分政策是否采用该口径，需要单独确认。

> 边界需修正：均分0在现有返回表达式中可能被转为 null；无 ACTIVE 时自动回退规则，与 SPEC 不允许无生效规则发布的目标不同。当前主要在查询/发布时计算，未发现完整的事件驱动重算任务链。

5.9 期末报告生成、发布、查阅与打印

1. 管理员提交 studentIds、termId。publishBatch 逐个核对学生存在和账号状态，再调用评分引擎检查六维是否存在。
2. 查询学科与已通过荣誉，组装 snapshot_json；生成固定格式的等级和模板评语，自述及家长寄语也采用代码模板。
3. 读取 MAX(version)+1，将历史报告置 SUPERSEDED，插入新 PUBLISHED 报告与审计。当前没有先读取 CONFIRMED 草稿再发布的完整过程。
4. 返回 published 与 blocked 列表。当前各 SQL 不在显式发布事务内，字段引用与仓库 DDL 仍有差异，需要实际库核对。

5. 报告查询只取本人/指定学生当前学期最新 PUBLISHED；学生第一次查看会写 read_at，这只表示查阅，不是家长已阅确认。
6. export-pdf 路由查询报告并返回带学生信息、时间水印与校验字符串的 HTML；浏览器自行打印。没有 jobId、异步轮询、二进制 PDF 或5分钟签名下载链接。

> 当前高优先级问题：打印路由未挂 requireAuth，按 ID 查询也未加学校/本人/发布态约束；HTML 直接插入部分业务文本。它是现有接口缺口，不是允许匿名查看学生报告的业务设计。

5.10 调度、消息与日志

机制	当前行为	实际限制
卡过期扫描	服务启动先执行一次，后每10分钟更新历史月份卡；另有 manager 手动触发接口	WHERE status=ACTIVE 与 DDL 的 UNUSED 不一致；没有待审宽限过期任务。
Outbox 扫描	每30秒查待发记录；模拟成功后更新为 SENT，失败递增重试计数	使用 payload/status/retry_count，与 DDL 的 payload_json/state/attempts 不一致；未真实发送。
失败处理	部分 catch 打日志或返回0，Outbox 外层异常被吞掉	没有持久任务进度、失败告警、投递渠道与完整重试计划。
审计查询	按 school_id 返回最近100条，关联用户姓名	不同控制器写入字段和 action 值并未完全统一。
请求日志	requestIdMiddleware、Morgan、结构化 logger	不能替代权限检查；二维码 token 等敏感查询串的记录策略需审查。

5.11 异常处理与可见反馈

场景	当前处理	仍需注意
密码/会话异常	登录失败、停用账户返回业务错误；JWT 验证失败返回401；前端清本地状态跳登录	黑名单查询失败当前降级放行；多校同名账号和会话权限变更需补处理。
卡片不可用	PENDING/USED/VOID 多为409，EXPIRED 多为400；前端展示原因	当前并未完整核对有效期和学校，错误分支不能覆盖所有非法场景。
重复冲销	唯一键及原流水关联检查，返回4095	重复直评/制卡不具备同等稳定幂等返回。
维度缺失	引擎返回 isComplete=false 和 null 总分；发布放入 blocked	前端接收字段不同可能误显示；需先对齐契约。
导入异常	预览返回逐行错误；分值超范围和学生未找到标错	确认端信任客户端内容，未绑定预览结果；异常行可被跳过。
SQL / 其他异常	统一 errorHandler 将 ER_* 变为“数据库操作失败”，其他异常为500	不一定带 data；调用失败可能源于 schema 差异，不能宣称事务测试已通过。
过载	当前限流15分钟最多500次；JSON body limit 5mb；前端 Axios 超时5分钟	这不是经过容量验证的 SLO；导入30秒解析超时等规划能力尚未实现。

六、限制、风险与待确认事项

6.1 当前实现差距与风险控制

以下项目来自源码与仓库 DDL 的静态比对，是本次现状评审的重点；没有据此推断所有真实环境都已发生故障。风险等级用于安排复核优先级，不是正式漏洞定级。

编号	优先级	事项	当前证据	主要位置	处理边界
R01	高	报告访问及对象范围	export-pdf 未鉴权；多个按ID操作缺本校/本人/任教校验；学生/教师列表仅要求登录。	routes/api.js；reportController；cardController；honorController	在生产开放前补齐一致的角色、学校、对象归属检查；当前不作安全完备承诺。
R02	高	跨接口字段契约	导入 records/items、subject/SUBJECT、diff_items/diffs；积分 summary、综合 calculation 与服务端返回不一致；部分样例维度为 X。	frontend/src/app/admin/import.jsx；dashboard/index.jsx；student/evaluation.jsx；对应 Controller	以双方实际 DTO 为据统一字段、类型、枚举和示例，补 HTTP 端到端验证。
R03	高	数据库字段不一致	报告引用学科 score、荣誉 award_name/points 等而 DDL 为 raw_score、title/honor_points；部分直评审计写 operator_id/action_type 等旧字段。	reportController；scoreController；sql/00_full_schema.sql	先核对实际 SHOW CREATE TABLE；不能仅凭注释认定可执行。

编号	优先级	事项	当前证据	主要位置	处理边界
R04	高	重复提交与额度	直评请求键随机尾缀、制卡从最大序号继续追加；月配额与生成数量未形成完整控制。	scoreController.directScoreBatch；cardController.generateMonthCards	补稳定请求语义、重复返回及额度闭环；本版只描述现状。
R05	高	报告发布完整性	绕过独立教师确认，缺 ACTIVE/学期门禁，未包发布事务；自述和家长寄语来自模板。	reportController.publishBatch	业务确认当前发布口径，整改后才能声称符合 SPEC 六项门禁。
R06	高	定时器与消息	ACTIVE/UNUSED，status/state，payload/payload_json，retry_count/attempts 不一致；发送仅模拟。	services/scheduler.js；DDL	修正字段并验证实际过期和投递；模拟 SENT 不等于送达。
R07	高	评分口径与版本	直接取最新故事覆盖 G；正式分未筛 CONFIRMED/最新版本；无规则默认回退；均分0返回异常。	services/evaluationEngine.js	确认现行算法是否可作为正式评分，增加边界和版本选择验证。
R08	高	材料与导入留痕	荣誉事件键含时间尾缀、补交不限前态；初次主/材料不原子；导入 UPSERT 可覆盖旧成绩。	honorController；importController	明确去重键、状态流和版本规则，先避免把多版本设计描述为已完全实现。
R09	中高	身份与运行安全	默认开发密钥/数据库账号；Token classes 为快照；黑名单异常放行；全局禁用 CSP。	middleware/auth.js；db.js；app.js	环境加固与会话策略需评审；不得使用示例凭据作为生产配置。
R10	中高	版本与部署资料	Docker Node20 已 EOL；缺编排/HTTPS/备份方案；旧 seed 脚本角色与业务 schema 不一致。	两个 Dockerfile；scripts/seed.js；init_db_data.js	升级受支持版本前做依赖验证，确认迁移、备份和实际部署路径。
R11	中	未具备的完整业务	无账号后台、真实AI、文件上传、消息中心、终审报告确认、荣誉撤销、完整归档/超管纠错。	路由总线与实际页面清单	按当前范围评审；如需增加，另立需求/版本，不混入当前验收。

6.2 数据安全、备份和运行约束

- 当前已使用密码散列、JWT、SQL 占位参数、若干角色中间件、部分行锁与唯一约束；这些是已有基础，不等于全域权限和隐私保护已验收。
- 包含未成年人姓名、班级、故事、证书与成绩，输出与日志应最小化；现代码卡列表含 token_hash、预览教师名未脱敏、打印含完整 username，需由业务和技术共同复核。
- 未发现完整备份/恢复自动化、RPO/RTO 实测、数据库就绪检查、任务告警或保留/销毁策略；不得在评审中填成已达标指标。
- Node 进程的定时任务遇进程退出会停止，多实例会重复启动；当前以单应用进程结构说明，不宣称已支持可靠分布式调度。
- 生产运行账号、密钥轮换、HTTPS 终止、数据库最小权限、日志访问权限、数据保留期限与备份位置均列为部署确认项；本次未修改或读取实际密钥。

6.3 需按当前版本确认的事项

编号	需确认的问题	当前事实 / 本版处理	确认责任
D01	本次评审的交付边界	以本文件19个非错误视图和现有接口/SQL为边界；31页原型仅作后续设计参考。	产品 / 技术
D02	哪些流程允许进入真实学生试用	先核对 R01—R10；当前文档不对未测试链路给出上线结论。	校方 / 技术
D03	综合权重和阈值是否正式采用	代码有80/15/5及20/12回退值，不能据此认为校规已批准。	校方 / 教研
D04	故事 G 的正式口径	当前为最新 REVIEWED 故事终审分覆盖；不是月平均或外部成绩合成。	教研组
D05	报告模板评语、自述与寄语能否展示	当前为代码模板生成，不能冒充师生/家长真实输入；试用需明确标识。	校方 / 产品
D06	报告发布是否要求班主任先确认	当前接口直接生成 PUBLISHED；如要求完整确认，属于待补能力。	校方 / 技术
D07	导入 API 的统一契约	明确 type、items/records、diffs、维度G、版本覆盖与异常行策略。	前后端负责人
D08	运行数据库与仓库 DDL 是否一致	需导出实际表结构，核对字段、枚举、索引和初始化脚本影响。	DBA / 技术
D09	卡配额、月底失效与审核宽限期	配额已保存，但制卡未严格消耗配额；完整宽限过期未实现，文案不能替代能力。	校方 / 技术
D10	实际部署环境与数据治理	配置参数、受支持运行时、域名/HTTPS、备份、恢复、保留与访问权限尚需核验。	运维 / 校方

确认原则：没有答复或没有异议，不视为业务参数和新增功能已经批准。本章待确认项不自动变成现有系统功能。

6.4 验证范围与当前验收证据

证据	已具备 / 本次执行	不能证明什么
源码与路由	本次已核对页面、菜单、路由、Controller、引擎、调度、Dockerfile 和 DDL。	不能替代真实 HTTP 调用、数据库约束或生产部署验证。
现有测试文件	backend/__tests__/health.test.js、system.test.js 已存在；后者会操作数据库，本次未运行。	部分测试直接写 SQL 安排状态，不足以证明接口鉴权、并发、幂等全通过。
先前原型检查	独立 HTML 原型有浏览器检查记录。	不证明当前 React 工程和后端接口已经端到端闭合。
本文档检查	校验结构、目录锚点、接口/页面/表数量、图表排版及可打印样式。	文档通过检查不代表系统功能通过验收。

评审后的验证应优先围绕现有流程展开：同卡并发申领、跨校/越班访问、重复直评/制卡、重复冲销、荣誉补交、故事终审、导入字段契约、六维缺项、报告发布与打印访问。任何需要新增能力的事项应另列整改任务，不在本文伪装成已完成。

6.5 维护与变更原则

本文件不调整产品代码或数据库。后续若修复契约/状态/权限，应同步更新接口清单、DDL 迁移、当前口径和测试证据；若新增原型中的未实现模块，应提升文档版本并明确新增范围。运行镜像或数据库升级要先在隔离环境验证，不将已有 Dockerfile 等同于可直接用于生产的部署基线。

七、评审与审批确认

7.1 本次确认项

□ 确认本文件以当前代码实现为基线，参考附件仅用于结构和版式。

□ 确认三角色、已有页面/接口/17张仓库表的现状清单与职责划分。

□ 确认扫码先待审、教师通过后 +1，无卡直评与冲销的实际处理方式。

□ 确认当前 AI 为模拟建议、导入为 JSON 接口、PDF 为 HTML 打印视图。

□ 确认最新故事覆盖 G、无规则默认回退及报告直接发布是现有口径，而非已经批准的最终校规。

□ 确认第六章列出的字段/状态/权限/部署问题需要独立核验和安排整改。

□ 确认未实施功能不计入当前交付；不以原型页数或规划状态机代替运行验收。

7.2 评审结论与签字

评审结论：□ 现状说明准确 □ 有条件通过，整改后复核 □ 退回修改。

学校 / 业务负责人签字： 日期：	产品 / 项目负责人签字： 日期：	技术 / 运维负责人签字： 日期：

未关闭事项 / 责任人 / 复核时间：_____

签字表示对本次实现现状与评审范围的确认；如用于上线审批，还需附实际环境、接口/并发/安全/恢复验证证据，不能仅凭本文档替代。

7.3 参考资料与复核入口

编号	资料	用途
REF-01	附件：学生学期评价系统-概要设计.html，v0.2	章节、术语表、模块表、提示块与签字区的风格参考。
REF-02	frontend/src/App.jsx、constant/menu.jsx、constant/urls.js、各 app 页面	真实路由、菜单、接口调用及字段读取。
REF-03	backend/routes/api.js、routes/auth.js、routes/health.js	当前接口路径与路由级中间件。
REF-04	backend/controllers/*.js、services/evaluationEngine.js、services/scheduler.js	业务写入、计算、发布、打印和定时扫描实现。
REF-05	sql/00_full_schema.sql；backend/db.js；middleware/*.js	17张表、数据库连接与权限/异常逻辑。
REF-06	frontend/backend 的 package.json、Dockerfile、.env.example；初始化脚本；测试文件	依赖与容器定义、示例配置、初始化差异与验证现状。
REF-07	SPEC 正文V2.1、实施计划、全模块原型与三角色操作逻辑图	仅用于背景和差距说明，不作为“当前已实现”的证据。
REF-08	Node.js 官方版本发布状态，2026-10-23查阅	现有 Node20 镜像维护风险的外部依据。